PATCH MANAGEMENT

WyIT - 3021

PURPOSE: This policy provides ongoing and consistent systems and applications, which are critical for a secure operational environment, by enforcing regular security updates and patches.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by the WyIT - 3002 - Security Exception Request policy.

IV. REQUIREMENTS

Regular application of properly licensed, affiliate-issued critical security updates and patches is necessary to protect data and systems from malicious attacks, compromise, and known vulnerabilities. All electronic devices connected to the state network, including servers, workstations, firewalls, network switches and routers, tablets, mobile devices, cellular devices, operating systems, office productivity software, database software, and affiliate applications, routinely require patching for functional and secure operations. Patches will be applied regularly within the timeframes outlined in Table 4 of WyIT 3020, Vulnerability Scanning.

V. AUTOMATED PATCHING PROCEDURES

Many affiliates have automated patching procedures for individual applications and affiliate tools in coordination with the CIO; only approved management software to support this process across the enterprise is authorized. Regular application of critical/high-security patches is reviewed as part of normal change management and audit procedures.

VI. PATCHING EXCEPTIONS

Production system patches may require complex testing and installation procedures. In certain cases, a security exception request may be required. The reason for departing this policy and the alternative protection measures to be taken shall be documented in writing, approved through a security exception request, and approved by the CIO. Deviations from normal patch schedules require the CIO's approval.

VII. SECURITY PATCHING PROCEDURES

CIO established policies and procedures must be adhered to for vulnerability and patch management, ensuring application, system, and network device vulnerabilities are:

- Evaluated regularly and responded to in a timely fashion.
- Documented and well understood by support staff.
- Automated and regularly monitored.
- Executed in a manner applicable to affiliate-supplied tools on a regularly communicated schedule.
- Applied in a timely and orderly manner based on the criticality and applicability of patches and enhancements.

VIII. SYSTEM REBOOT CYCLE

State-authorized and owned systems will be required to reboot at the discretion of the patching job. These required reboots will be administered via patch management software, the specific patching job configurations, and the operating system. The required reboots shall include notifications that proactively inform end users of the reboot, provide a window of time and limited deferrals to save work and restart their system. If the window of time is exceeded or the deferrals are

depleted, the forced reboot will occur. The operating system will force such reboots to ensure each system meets the minimum requirements. The patching job will define all reboots. Any deviation from this policy will result in a security exception request to be processed.

IX. AUDIT CONTROLS AND MANAGEMENT

On-demand documented procedures and evidence of practice shall be in place for this operational policy as part of the CIO's internal systems change management and update procedures. Examples of adequate controls include:

- Documented change management meetings and conversations between key state stakeholders.
- System updates and patch logs for all major system and utility categories.
- Outlined in Wyoming Statute § 9-2-2904(a)(i), this policy applies to all executive branch agencies, boards and commissions, and state personnel members, including, but not limited to, full-time employees, part-time employees, trainees, volunteers, contractors, and temporary workers. Additionally, some affiliates, such as contractors or vendors, may be required to adhere, as indicated in contractual requirements.
- Logs shall include system ID, date patched, patch status, exception, and reason for exception.
- Demonstrated infrastructure supporting enterprise patch management across systems, applications, and devices.

REFERENCES

- WyIT - 3020 - Vulnerability Scanning

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
June 2024	ETS Governance, Risk and Compliance	Public Comment Period	05/10/2024 - 05/24/2024	June 2024

REVISIONS		
LAST REVISION DATE	**LAST REVISED BY**	**LAST APPROVED BY**

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**